

Conceitos básicos de segurança da informação

Métodos de avaliação de risco

Métodos de avaliação de risco

Como a norma 27005:2011 foi feita pensando em ser abrangente, o processo é bem detalhado, porém nunca é especificado, para que seja possível se encaixar em qualquer organização de acordo com seus contextos e definições específicas.

Análise qualitativa

A análise qualitativa de risco é empregada para classificar um risco por meio de termos ou palavras (como baixo, médio ou alto risco) que procuram quantificar o impacto das consequências de um risco específico, considerando as probabilidades de sua ocorrência. O objetivo deste método é adquirir uma compreensão mais aprofundada do evento de segurança por meio da coleta de dados e das características apresentadas.

Análise qualitativa

Este método é mais comumente utilizado quando estamos nas fases iniciais do processo, auxiliando a identificação dos riscos relativos que podem ter um alto nível crítico. Ele é rápido e fácil de ser efetuado, permitindo que a organização utilize a experiência e conhecimento do gerente de riscos sobre o ativo a ser avaliado.

Análise qualitativa

Impacto				
		Baixo	Médio	Alto
Probabilidade	Baixa	Baixo Risco	Baixo Risco	Médio Risco
	Média	Baixo Risco	Médio Risco	Alto Risco
	Alta	Médio Risco	Alto Risco	Alto Risco

Análise quantitativa

Já a avaliação quantitativa do risco se concentra em dados, fatos e medidas mensuráveis com embasamento matemático e computável. Por depender de medidas e efetuar uma análise mais minuciosa este método é mais custoso e lento, porém gera resultados mais confiáveis e imparciais.

Análise quantitativa

Geralmente, o resultado desta análise pode ser expresso em termos de perdas financeiras relacionadas ao evento de segurança sendo analisado. Utilizando conceitos de estatística e probabilidade é possível calcular estimativas de possíveis perdas em cada cenário.